From Weak Signals to OEM Risk: Graph-Grounded Agentic Cyber Supply-Chain Intelligence

Anonymous Submission

***Abstract*—Public cyber reports can offer early warning of supply-chain disruption, but they do not by themselves establish whether an incident matters to a specific manufacturer. A moderate incident at a critical supplier may create more downstream risk than a severe incident at a redundant one. We present a graph-grounded agentic framework that filters non-actionable reports, resolves affected suppliers to an OEM dependency graph, correlates same-event reports, and separates supplier-side consequence from OEM-side exposure before assigning risk. We evaluate the framework on 129 controlled reports grounded in a Honda supply-chain graph derived from MarkLines data. With GPT-4.1, the framework misses 4 of 99 actionable reports while producing no false alerts among 30 non-actionable reports, and achieves 0.850 supplier micro-F1, 0.750 pairwise merge F1, and 0.620 risk QWK. Against a matched monolithic graph-tool baseline, it reduces median latency by 46% and API cost by 53%. In a directly matched GPT-5.4 claim audit, the framework yields an unsupported-claim rate of 0.042 versus 0.257 for the matched monolithic baseline. Across four local backends, no false alerts are observed among the 30 non-actionable reports; Qwen3-14B has the lowest miss rate at 8/99 actionable reports. In a separate 20-incident study, privacy-bounded query expansion retrieves 39 of 40 withheld same-incident reports and increases evidence coverage from 0.019 to 0.529. A manual audit of the 100 generated queries finds no prohibited graph attributes.**

***Index Terms*—cyber supply-chain intelligence, supply-chain security, LLM agents, risk assessment, knowledge graphs**

1. Introduction

Cyber incidents at external suppliers can affect organizations far beyond the one directly compromised. For an original equipment manufacturer (OEM), however, cyber severity alone is not enough to determine risk. A disruptive ransomware incident at a redundant supplier of a non-critical component may have limited downstream effect, while a shorter disruption at a sole-source supplier may threaten several products or production programs. Cyber supply-chain intelligence must therefore go beyond asking what happened. It must also ask whether the incident matters to this organization, and through which dependencies. NIST supply-chain risk-management guidance likewise emphasizes visibility into supplier and product dependencies [1].

Public reports, supplier disclosures, security advisories, and other open sources carry early signals, but turning them into an OEM-specific assessment is difficult. Reports may use different supplier aliases, describe the same incident using different wording, or omit important operational details during the early stages of a disruption. Prior work has advanced CTI extraction, knowledge-graph construction, LLM-based CTI reasoning, and agentic evidence enrichment [2]–[4]. Supply-chain structure and stakeholder context also matter for cyber-risk prioritization [5], [6]. These capabilities are usually studied separately, leaving a gap between an evolving external cyber incident and the concrete downstream dependencies of a target organization. We address this gap with a graph-grounded agentic framework that connects the two: it checks incoming reports for cyber and OEM relevance, resolves affected organizations against the supply-chain graph, and correlates same-event reports into a canonical incident. When the available reporting is incomplete, an optional query-expansion agent identifies evidence gaps and retrieves additional public information before consequence assessment. External queries are derived only from public incident evidence and cannot access private OEM-graph attributes. The framework then assesses supplier-side incident consequence and OEM-side exposure separately before combining them into an auditable OEM-specific risk decision. We evaluate the framework on 129 controlled reports grounded in a Honda supply-chain graph, comparing it with deterministic rules, a single LLM, a matched graph-tool baseline, a GraphRAG baseline, and four ablations. Query expansion is evaluated separately.

Contributions. (1) We formulate cyber supply-chain monitoring as an organization-specific risk-intelligence problem in which actionability depends jointly on external incident evidence and the target organization's dependency structure; (2) we introduce a graph-grounded agentic architecture combining supplier resolution, cross-source incident correlation, privacy-bounded evidence expansion, and separate reasoning over supplier consequence and OEM exposure; and (3) we evaluate the framework across detection, grounding, correlation, ordinal risk, efficiency, faithfulness, local deployment, and controlled evidence enrichment.

2. Related Work

LLM and agentic cyber intelligence. Language models have been used for CTI extraction, knowledge-graph construction, and cyber-reasoning benchmarks [2], [3], [7]–[9]. TACTIC-KG decomposes knowledge-graph construction across small agents [10], while Beyond RAG compares

vector, graph-based, agentic, and hybrid retrieval strategies [11]. IntelForge distributes CTI enrichment across extraction, retrieval, scoring, and reporting agents [4], while trust-adaptive retrieval controls the use of external cyber evidence [12]. These systems primarily enrich or structure threat information. We ask instead whether an external cyber incident is material to a specific OEM, given the OEM's existing supplier and product dependency graph.

OEM-specific exposure and incident correlation. Organization-specific vulnerability prioritization and materiality studies show that general cyber severity does not directly determine organization-specific impact [5], [13]. Supply-chain guidance and empirical analyses likewise treat supplier and product dependencies as relevant to enterprise cyber risk [1], [6]. AlMahri et al. [14] map disruption reports onto multi-tier supplier networks for exposure and mitigation planning. We instead focus on cyber incidents, explicitly evaluate cross-source correlation, separate supplier consequence from OEM graph exposure, and compare the decomposition with matched monolithic, GraphRAG, and ablated controls. Cross-document event-coreference research further shows that event identity cannot be determined from lexical overlap alone [15]–[17], so we evaluate incident correlation explicitly.

Privacy-bounded evidence expansion. Retrieval can expose sensitive information through outbound queries independently of leakage from retrieved documents [18], [19]. In an OEM setting, queries containing sole-source status, criticality, downstream reach, or vehicle programs could reveal proprietary supply-chain topology. We therefore deny the query-expansion agent access to OEM-graph attributes and evaluate generated-query disclosure directly.

3. Method

Fig. 1 summarizes the workflow. The framework separates reasoning over external cyber reports from OEM-specific supply-chain knowledge. Specialized agents process the public incident evidence, while proprietary dependency information is accessed only through a replaceable graph interface. Another OEM dependency graph can replace the evaluation graph without changing the agent decomposition or retraining the language models.

3.1. Problem Formulation and Graph Interface

Let $a_i = (h_i, b_i, m_i)$ denote an incoming report containing a headline, body, and optional metadata, and let $G = (V, E)$ denote the dependency graph of the target OEM. The system predicts whether the report describes a cyber event, $\hat{c}_i$, and whether the affected organization is grounded in the OEM graph, $\hat{q}_i$. Its actionable prediction is $\hat{y}_i = \hat{c}_i \wedge \hat{q}_i$. Actionable reports describing the same real-world event are correlated into a canonical incident I_j. Each incident receives a supplier-side consequence assessment S_j and a graph-grounded OEM-exposure assessment E_j. The final ordinal risk is $R_j = F(S_j, E_j)$, where $R_j \in \{\text{VERY LOW}, \text{LOW}, \text{MEDIUM}, \text{HIGH}, \text{VERY HIGH}\}$. The supply-chain graph is not encoded in the model parameters. Agents access it through a fixed interface supporting organization and alias lookup, supplied products and component categories, vehicle dependencies, sourcing alternatives, criticality, bottleneck status, and downstream reach. This keeps organization-specific knowledge outside the model parameters.

3.2. Agentic Workflow

Triage, grounding, and correlation. Agent 1 converts each report into a structured evidence record. It extracts organization mentions, cyber indicators, event details, temporal information, operational effects, and supporting source evidence, and predicts the cyber label $\hat{c}_i$. Agent 2 normalizes the organization mentions and resolves them against canonical supplier identities and aliases exposed by the graph interface. It returns the resolved supplier identifiers and OEM-relevance label $\hat{q}_i$.

The framework then applies the actionable gate: only reports satisfying $\hat{c}_i \wedge \hat{q}_i$ continue downstream. This keeps off-graph cyber events and in-graph non-cyber reports out of later correlation and risk reasoning. Agent 3 determines whether each actionable report describes a new incident or an event already observed. Correlation uses supplier identity, event type, timing, operational effects, and the factual narrative rather than lexical similarity alone. Same-event reports are merged into a canonical incident while retaining their report identifiers and accumulated evidence. Separate incidents involving the same supplier remain distinct.

Evidence expansion and separate risk views. Agent 4 optionally enriches a canonical incident when the available public reports leave important evidence unresolved. It identifies gaps such as disruption scope, affected operations, recovery status, duration, or technical attribution and generates up to K targeted retrieval queries ($K = 5$ in the evaluation). Query generation uses only public incident evidence. Agent 4 has no access to supplied products, vehicle programs, criticality, sourcing redundancy, bottleneck status, or downstream dependencies from the OEM graph. Retrieved documents are accepted only when they describe the same incident and add evidence not already present in the canonical incident. If no candidate satisfies both conditions, the original incident is returned unchanged. When query expansion is disabled, Agent 5 receives the original canonical incident directly.

Agent 5 evaluates the consequence of the cyber event at the affected supplier, independently of its importance to the OEM. It considers operational disruption, affected facilities or operations, temporal status, and recovery evidence, producing the supplier-side assessment S_j. Independently, Agent 6 uses the resolved supplier and graph interface to assess the OEM's exposure. It retrieves supplied products and component categories, affected vehicle programs, sourcing alternatives, criticality, bottleneck information, and downstream reach, producing E_j.

Keeping Agents 5 and 6 separate prevents general cyber severity from becoming a proxy for OEM impact. A severe

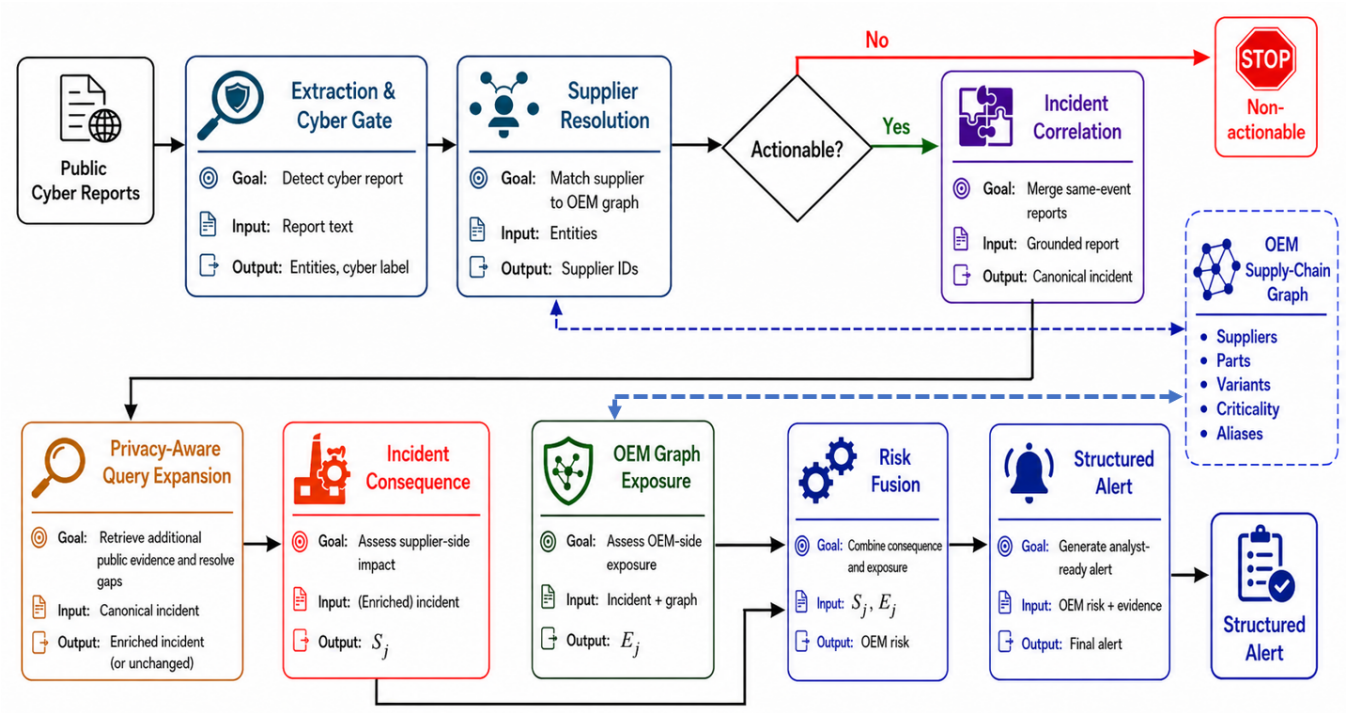


Figure 1. Graph-grounded cyber supply-chain monitoring. Reports are filtered, supplier-grounded, and correlated before separate supplier-consequence and OEM-exposure assessment. Optional public-evidence retrieval remains isolated from the proprietary OEM graph.

incident at a supplier with readily available substitutes may create limited OEM exposure, while a more moderate incident at a critical sole-source supplier may create substantial downstream risk.

Risk fusion and structured reporting. Agent 7 combines the supplier consequence S_j and OEM exposure E_j under the fixed five-level risk schema. It considers operational disruption and recovery together with graph-grounded criticality, redundancy, bottleneck status, product breadth, and downstream reach. It also records the incident and exposure factors supporting the decision, so operators can trace the final risk separately to public report evidence and OEM graph evidence.

Agent 8 converts the completed assessment into an operator-facing cyber supply-chain alert. The alert contains the affected supplier, incident state, relevant dependency paths, assigned risk, supporting factors, and source provenance. Because report generation is separate from risk reasoning, we can evaluate final-output faithfulness independently.

4. Evaluation

We study four questions. *RQ1*: Can the framework identify and ground actionable OEM-relevant cyber reports? *RQ2*: Do incident correlation, graph-derived exposure, and staged risk reasoning improve OEM-risk assessment? *RQ3*: What quality, faithfulness, latency, cost, and deployment trade-offs arise across architectures and model backends? *RQ4*: Can privacy-bounded query expansion recover missing incident evidence without exposing OEM-graph information and produce appropriate risk updates?

4.1. Evaluation Data

OEM graph and report corpus. The evaluation targets Honda using an automotive supply-chain graph constructed from MarkLines supplier and part-supply data [20]. The frozen graph contains 4,661 nodes, 26,035 edges, and 8,886 organization aliases. Its nodes represent organizations, supplied products, vehicle variants, and component categories, while its relations connect suppliers to products, components, vehicle programs, and OEMs. All graph-aware methods access the same graph through the same query interface. We begin with ten publicly reported cyber incidents from the automotive ecosystem. These incidents are semantic seeds with realistic combinations of cyber-event type, affected operation, disruption pattern, and reporting style. The generated reports do not claim that the substituted events actually occurred at the selected suppliers.

Using these seeds, we generate 100 controlled base reports with Claude Opus 4.8 at high effort. Each report preserves plausible cyber and operational characteristics but substitutes suppliers and dependencies drawn from the evaluation graph. We then create 29 cross-source variants of 25 actionable base reports; these preserve event identity while changing supplier surface forms, wording, secondary details, and reporting perspective. The resulting corpus contains 129 reports: 99 actionable in-graph cyber reports, 15 off-graph cyber reports, and 15 non-cyber reports involving in-graph

organizations. Of the 99 actionable reports, 45 are singleton incidents and 54 form 25 multi-report groups, yielding 34 positive merge pairs. The negative pair set includes 42 designed same-supplier/different-incident hard negatives that must remain distinct. The corpus covers 78 named graph suppliers and several exposure conditions, including bottleneck, sole-source, redundant, high-reach, low-reach, and multi-supplier cases.

Reference labels and human verification. The controlled construction provides exact labels for cyber status, OEM relevance, supplier identity, and incident-group membership. Reports representing the same controlled event share a group identifier, and actionability is defined as $y_{\text{actionable}} = y_{\text{cyber}} \wedge y_{\text{in-graph}}$. Five-level OEM-risk reference labels are assigned independently by Gemini 3.1 under a fixed rubric that combines represented incident consequence with graph-derived exposure. The generator, reference annotator, and evaluated pipelines use distinct model families; reference labels and incident-group identifiers are never provided to the tested systems. A domain-informed analyst independently reviewed 35 reports and their associated reference labels. Report-level assessments agreed in all 35 cases, while risk labels matched exactly in 30/35 cases (85.7%). The remaining five disagreements were each limited to one adjacent risk level. Disagreements were resolved by selecting the lower of the two adjacent ratings. The 20 query-expansion cases were also manually reviewed for same-incident identity and enriched-risk consistency.

4.2. Baselines and Ablations

We compare the full system, denoted OURS, with four baselines. **B0** combines deterministic cyber rules, entity and graph lookup, supplier-overlap-constrained embedding similarity for incident correlation, and fixed risk rules. **B1** is a single LLM without graph access. **B2**, our primary monolithic control, gives one LLM the same graph-query tools as OURS, so the comparison isolates staged decomposition rather than graph access. **B3** is a single-pass GraphRAG-style baseline that retrieves the relevant supplier neighborhood before one LLM call.

Four ablations test the decomposition. **A1** removes OEM-graph access, requiring supplier relevance and downstream risk to be inferred without graph grounding; **A2** removes incident merging, **A3** replaces the separate incident-consequence and graph-exposure stages with one unified risk agent, and **A4** removes the early actionable gate. All graph-aware methods use the same frozen graph, aliases, and query interface.

4.3. Metrics and Model Configurations

For actionable-report detection, we report false-negative rate (FNR; $\mathrm{FN}/99$) and false-positive rate (FPR; $\mathrm{FP}/30$), referred to operationally as miss and false-alert rates, together with the corresponding raw counts. For each method, FNR and FPR are computed from its report-level actionable decision against the reference actionable labels; for OURS, this decision is $\hat{y}_i = \hat{c}_i \wedge \hat{q}_i$. The corpus is asymmetric, with 99 actionable and 30 non-actionable reports; an always-actionable predictor would therefore achieve positive-class F1 of 0.868 while producing 100% FPR. We use FNR and FPR to expose this trade-off directly. The 30 negative reports comprise 15 off-graph cyber and 15 in-graph non-cyber reports; we report their error breakdown in Sec. 5.1. Given the small negative set, subtype differences are treated descriptively. Moreover, for 0/30 observed false positives, the exact two-sided Clopper–Pearson 95% interval has an upper bound of approximately 11.6%, so zero observed errors should not be interpreted as zero population FPR.

We report supplier micro-F1 over predicted versus reference canonical supplier identities for graph grounding. Pairwise Merge F1 evaluates incident correlation over all unordered pairs among the 99 ground-truth actionable reports. Reports not propagated to correlation are retained in this evaluation and counted as predicted non-merges rather than excluded.

For ordinal OEM risk, we report QWK, Spearman's ρ, and risk-assignment rate. QWK and ρ are computed over predictions that map to the fixed five-level risk schema; assignment rate is the fraction of the 99 actionable reports receiving such a valid prediction. Because agreement metrics are conditional on valid outputs, they should be interpreted together with assignment rate when coverage differs across methods. Operational measures are median latency and total API cost for the 129-report corpus, and final-alert faithfulness is measured using supported-claim and unsupported-claim rates.

The primary matched comparison uses GPT-4.1. We additionally evaluate GPT-5.4 and four local backends: Qwen3-14B, Qwen3-8B, Qwen3-4B, and GPT-OSS-20B. Local models run on one NVIDIA RTX 6000 Ada 48 GB GPU without hosted LLM fallback. Because model settings differ, this is a deployment-portability comparison rather than controlled parameter scaling. Detailed configurations are reported in the Appendix. For the primary B2 comparison and the A1/A3 risk ablations, uncertainty is estimated using 10,000 paired bootstrap resamples over ground-truth incident blocks, treating singleton reports as individual blocks; paired 95% CIs are reported in Table 4. Query expansion is disabled in the main benchmark because the controlled incidents do not exist on the public Web. We evaluate it separately.

4.4. Controlled Query-Expansion Evaluation

We evaluate Agent 4 on 20 pre-vetted actionable incidents spanning all six exposure strata and five original risk levels. Each incident has two withheld cross-source reports: eight cases support increased consequence, eight decreased consequence, and four no ordinal change. The 40 targets are mixed with 20 unrelated aerospace, aviation, and defense cyber reports in a frozen 60-document corpus. The enriched-risk reference uses the complete incident evidence and frozen graph context.

Agent 4 receives only the canonical incident, generates five public-evidence queries, and retrieves the top-ranked document per query without OEM-graph access. We report retrieval, acceptance-filter precision and recall, supplemental-evidence coverage, and risk-update direction, where supplemental-evidence coverage is the fraction of annotated supplemental facts reflected in Agent 5's structured consequence assessment. Query top-1 success is defined by the fraction of generated queries whose top-ranked retrieval is a relevant supplemental report. We also manually audit all 100 queries for prohibited graph-only attributes. Retrieval settings are reported in the Appendix.

5. Results

5.1. Primary Comparison

RQ1: Detection and supplier grounding. Table 1 shows that OURS has the strongest observed joint detection operating point: it misses 4/99 actionable reports and produces no false alerts among 30 negatives. B0 matches the four misses but produces 10/30 false alerts; B2 and B3 produce no false alerts but miss 13/99 and 62/99 reports, respectively; and B1 misses 9/99 while producing 15/30 false alerts. All B1 false alerts are off-graph cyber reports (15/15), while B0's comprise eight off-graph cyber and two in-graph non-cyber reports. Supplier micro-F1 is 0.850 for OURS, compared with 0.808 for B2 and 0.602 for B0.

RQ2: Correlation and OEM-risk reasoning. Merge F1 is 0.750 for OURS versus 0.634 for the matched B2 baseline; Table 1 reports the remaining methods. The correlation evaluation is highly imbalanced, with 34 positive pairs among 4,851 pairs. B1's nonzero correlation despite zero supplier-grounding F1 indicates that event-level evidence can support partial matching without canonical graph identities. OURS also reaches risk QWK of 0.620 and Spearman's $\rho = 0.670$, versus 0.589 and 0.558 for B2; both assign valid risk to 86/99 actionable reports (0.869). The point estimates favor OURS for grounding, correlation, and risk agreement, although the paired 95% intervals include zero (Table 4).

RQ3: Quality–efficiency trade-off. In the primary GPT-4.1 comparison, OURS combines the strongest observed joint detection operating point with the highest grounding, correlation, and risk-agreement point estimates. Against B2, median latency falls from 14.2 s to 7.7 s (46%) and total API cost from \$2.53 to \$1.19 (53%). In the matched GPT-5.4 audit, the unsupported-claim rate also falls from 0.257 for B2 to 0.042 for OURS (Sec. 5.3).

5.2. Ablation Study

The ablations affect different stages (Table 2). Removing OEM-graph access (A1) raises FNR from 4.0% to 15.1% and FPR from 0.0% to 50.0%; all 15 false alerts are off-graph cyber reports, while all 15 in-graph non-cyber reports are rejected. A2 and A3 preserve OURS's 4.0% FNR and 0.0% FPR. A4 records 12.1% FNR and 0.0% FPR; because it removes a control-flow gate rather than a detection model, we treat these detection counts descriptively.

The risk results separate two effects. Removing graph access (A1) reduces QWK from 0.620 to 0.292, capturing the end-to-end contribution of the OEM graph to risk assessment. A3 retains graph access but unifies supplier consequence and OEM exposure in one risk stage; its QWK falls to 0.354. Both differences are statistically resolved: OURS–A1 yields ΔQWK=+0.328 (95% CI [+0.221,+0.436]) and OURS–A3 yields +0.266 ([+0.160,+0.376]); Table 4 reports the paired comparisons.

A1 retains Merge F1 of 0.727 versus 0.750 for OURS, indicating that report-level event evidence still supports much of the correlation task without graph access. Removing Agent 3 (A2) instead collapses Merge F1 to 0 while QWK remains 0.526. A4 reduces QWK to 0.518 and raises cost from \$1.19 to \$1.39; we use these downstream results, not its detection counts, to assess the gate. Overall, graph access affects actionability and risk quality, while separate consequence–exposure reasoning improves ordinal risk agreement.

5.3. Deployment and Final-Alert Faithfulness

Table 3 summarizes deployment across hosted and local backends. GPT-4.1 and GPT-5.4 each miss 4/99 actionable reports with no false alerts among 30 negatives. GPT-5.4 has the highest risk agreement (QWK 0.640) but requires 15.5 s median latency and \$2.60 in API cost, versus 7.7 s and \$1.19 for GPT-4.1. All local backends also produce no false alerts. Qwen3-14B has the lowest local miss rate (8/99), Qwen3-8B achieves the highest supplier micro-F1 across all evaluated backends (0.870), and GPT-OSS-20B has the highest local QWK (0.562). Against its matched GPT-OSS B2 baseline, OURS improves supplier micro-F1 from 0.653 to 0.821. Across local backends, Merge F1 ranges from 0.696 to 0.715.

For final-alert faithfulness, a DeepEval claim–evidence audit using GPT-5.5 gives the directly matched GPT-5.4 OURS reports a supported-claim rate of 0.958 and unsupported-claim rate of 0.042, versus 0.743 and 0.257 for B2. Non-GPT-5.4 outputs use persisted structured claims rather than complete final reports and are therefore diagnostic.

5.4. Privacy-Bounded Query Expansion

Agent 4 retrieves 39/40 withheld reports, recovering at least one for all 20 incidents and both for 19/20. The filter retains all 39 targets plus one wrong-target same-supplier report (precision 0.975; recall 1.000), and a manual audit finds no prohibited graph attributes in 100 queries. Agent 5 changes consequence in 7/20 incidents (six increases, one decrease), while evidence coverage rises from 0.019 to 0.529. Final risk-update direction agrees with reference in 15/20 cases. Of the 16 cases whose supplemental evidence supports a consequence change, only eight require a different final ordinal risk; four change correctly and four

TABLE 1. MAIN GPT-4.1 COMPARISON ON 129 REPORTS. FNR IS FN/99 AND FPR IS FP/30; PARENTHESES GIVE RAW COUNTS. COST IS TOTAL API EXPENDITURE FOR ALL 129 REPORTS; LOWER IS BETTER FOR FNR, FPR, LATENCY, AND COST.

Method	FNR ↓	FPR ↓	Supplier μF1	Merge F1	Risk QWK	Assign. rate	Spearman ρ	Median (s)	Cost ($)
B0 Rules+Graph	4.0% (4)	33.3% (10)	0.602	0.681	0.405	0.960	0.546	0.350	0.00
B1 Single LLM	9.1% (9)	50.0% (15)	0.000	0.502	0.403	0.909	0.513	3.923	0.27
B2 LLM+Graph Tools	13.1% (13)	0.0% (0)	0.808	0.634	0.589	0.869	0.558	14.168	2.53
B3 GraphRAG	62.6% (62)	0.0% (0)	0.326	0.343	0.464	0.374	0.168	3.351	0.40
Ours	4.0% (4)	0.0% (0)	0.850	0.750	0.620	0.869	0.670	7.652	1.19

TABLE 2. GPT-4.1 ABLATIONS. RAW COUNTS ARE IN PARENTHESES; A1: NO GRAPH ACCESS; A2: NO MERGER; A3: UNIFIED RISK; A4: NO EARLY GATE. COST IS TOTAL API EXPENDITURE FOR ALL 129 REPORTS.

Variant	FNR ↓	FPR ↓	Merge F1	QWK	ρ	Med. s	$
Ours	4.0% (4)	0.0% (0)	0.750	0.620	0.670	7.7	1.19
A1: no graph access	15.1% (15)	50.0% (15)	0.727	0.292	0.411	6.9	1.03
A2: no merger	4.0% (4)	0.0% (0)	0.000	0.526	0.636	6.7	1.10
A3: unified risk	4.0% (4)	0.0% (0)	0.692	0.354	0.392	5.8	0.98
A4: no gate	12.1% (12)	0.0% (0)	0.757	0.518	0.629	7.8	1.39

remain unchanged, with none moving oppositely, while 11/12 reference-stable cases remain stable. Table 5 reports the complete results.

6. Discussion and Limitations

The results separate cyber triage from OEM relevance. B0 matches OURS's 4/99 misses but produces 10/30 false alerts. B1 misses 9/99 reports and accepts all 15 off-graph cyber reports while rejecting all 15 in-graph non-cyber reports. A1 repeats this subtype failure, with 15/99 misses and 15/30 false alerts, locating the graph's detection benefit in OEM relevance rather than cyber-event triage. Although A1 is weaker than B1 on detection, its staged design retains higher Merge F1 (0.727 versus 0.502).

The risk ablations separate graph access from decomposition. A1 lowers QWK from 0.620 to 0.292, capturing the graph's end-to-end contribution; A3 retains graph access but unifies supplier consequence and OEM exposure, lowering QWK to 0.354. The paired QWK intervals for A1 and A3 exclude zero, whereas the matched B2 intervals for grounding, correlation, and risk agreement include zero (Table 4). Local backends retain competitive detection, grounding, and correlation without hosted LLM inference, while query expansion improves evidence coverage but remains conservative for some evidence-supported risk changes.

The evaluation is controlled rather than observational. Reports are generated from real incident seeds, and five-level risk values are reference annotations under a fixed rubric rather than observed production losses. Human verification covers only part of the corpus, and evaluation uses one OEM graph. The closed retrieval corpus does not measure open-Web recall or source reliability, and hosted embeddings in the expansion experiment demonstrate graph isolation rather than fully local retrieval. External evidence may also be inaccurate, malicious, or prompt-injected and must remain untrusted. The matched faithfulness audit uses GPT-5.5 to evaluate GPT-5.4 outputs for both OURS and B2; this judge is applied symmetrically, although model-family proximity may affect the absolute audit rates. Cross-OEM portability is therefore an architectural property of the replaceable graph interface rather than an experimentally demonstrated result.

7. Conclusion

We presented a graph-grounded agentic framework for OEM-specific cyber supply-chain risk. On GPT-4.1, OURS has 4/99 misses, 0/30 false alerts, and the highest grounding, correlation, and risk-agreement point estimates, while cutting latency by 46% and API cost by 53% versus B2. Paired ablations show statistically resolved QWK losses when graph access is removed or consequence and exposure are unified. Local backends remain competitive, and privacy-bounded expansion retrieves 39/40 withheld reports with no prohibited graph attributes in 100 audited queries.

References

[1] J. Boyens, A. Smith, N. Bartol, K. Winkler, A. Holbrook, and M. Fallon, "Cybersecurity supply chain risk management practices for systems and organizations," National Institute of Standards and Technology, Gaithersburg, MD, USA, NIST Special Publication 800-161 Rev. 1 Update 1, 2024.

[2] G. Wang, P. Liu, J. Huang, H. Bin, X. Wang, and H. Zhu, "KnowCTI: Knowledge-based cyber threat intelligence entity and relation extraction," *Computers & Security*, vol. 141, p. 103824, 2024.

[3] L. Huang and X. Xiao, "CTIKG: LLM-powered knowledge graph construction from cyber threat intelligence," in *Proceedings of the First Conference on Language Modeling (COLM)*, Philadelphia, PA, USA, 2024.

[4] N. Tarshish, D. Hodisan, and A. Shabtai, "IntelForge: Multi-agent LLM framework for cyber threat intelligence enrichment," in *2025 Annual Computer Security Applications Conference Workshops (ACSAC Workshops)*. IEEE, 2025, pp. 374–381.

[5] O. A. Haddad, M. Ikram, M. E. Ahmed, and Y. Lee, "Prompting the priorities: Evaluating LLMs for organization-specific vulnerability prioritization," in *2025 Annual Computer Security Applications Conference Workshops (ACSAC Workshops)*. IEEE, 2025, pp. 341–348.

[6] K. Hu, R. Levi, R. Yahalom, and E. G. Zerhouni, "Supply chain characteristics as predictors of cyber risk: A machine-learning assessment," *IEEE Transactions on Dependable and Secure Computing*, vol. 22, no. 5, pp. 5648–5657, 2025.

[7] R. Fieblinger, M. T. Alam, and N. Rastogi, "Actionable cyber threat intelligence using knowledge graphs and large language models," in *2024 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*. IEEE, 2024, pp. 100–111.

[8] M. T. Alam, D. Bhusal, L. Nguyen, and N. Rastogi, "CTIBench: A benchmark for evaluating LLMs in cyber threat intelligence," in *Advances in Neural Information Processing Systems*, vol. 37. Curran Associates, Inc., 2024, pp. 50 805–50 825.

[9] M. T. Alam, D. Bhusal, S. Ahmad, N. Rastogi, and P. Worth, Jr., "AthenaBench: A dynamic benchmark for evaluating LLMs in cyber threat intelligence," in *2025 Annual Computer Security Applications Conference Workshops (ACSAC Workshops)*. IEEE, 2025, pp. 443–450.

[10] M. A. Bouchiha and G. Blanc, "TACTIC-KG: Toward small agent teams for cyber threat intelligence knowledge graph construction," *arXiv preprint arXiv:2607.05001*, 2026.

[11] D. Hamzić, F. Skopik, M. Landauer, M. Wurzenberger, and A. Rauber, "Beyond RAG for cyber threat intelligence: A systematic evaluation of graph-based and agentic retrieval," *arXiv preprint arXiv:2604.11419*, 2026.

[12] J. Guntupalli and K. Watanabe, "Trust-adaptive agentic retrieval framework for LLM-based cyber threat intelligence," in *2025 Annual Computer Security Applications Conference Workshops (ACSAC Workshops)*. IEEE, 2025, pp. 473–479.

[13] G. I. Akalin and N. Zhou, "Cybersecurity threat intelligence for audit: LLM scoping, evidence guardrails, and materiality," in *2025 Annual Computer Security Applications Conference Workshops (ACSAC Workshops)*. IEEE, 2025, pp. 414–419.

[14] S. AlMahri, L. Xu, and A. Brintrup, "Automating supply chain disruption monitoring via an agentic AI approach," *arXiv preprint arXiv:2601.09680*, 2026.

[15] A. Cybulska and P. Vossen, "Using a sledgehammer to crack a nut? lexical diversity and event coreference resolution," in *Proceedings of the Ninth International Conference on Language Resources and Evaluation (LREC'14)*. Reykjavik, Iceland: European Language Resources Association, 2014, pp. 4545–4552.

[16] M. Bugert and I. Gurevych, "Event coreference data (almost) for free: Mining hyperlinks from online news," in *Proceedings of the 2021 Conference on Empirical Methods in Natural Language Processing*. Online and Punta Cana, Dominican Republic: Association for Computational Linguistics, 2021, pp. 471–491.

[17] A. P. B. Veyseh, V. D. Lai, C. Nguyen, F. Dernoncourt, and T. Nguyen, "MCECR: A novel dataset for multilingual cross-document event coreference resolution," in *Findings of the Association for Computational Linguistics: NAACL 2024*. Mexico City, Mexico: Association for Computational Linguistics, 2024, pp. 3869–3880.

[18] T. Koga, R. Wu, and K. Chaudhuri, "Privacy-preserving retrieval-augmented generation with differential privacy," *arXiv preprint arXiv:2412.04697*, 2024.

[19] Y. Wang, W. Qu, S. Zhai, Y. Jiang, Z. Liu, Y. Liu, Y. Dong, and J. Zhang, "Silent leaks: Implicit knowledge extraction attack on RAG systems through benign queries," *arXiv preprint arXiv:2505.15420*, 2025.

[20] MarkLines Co., Ltd., "Marklines automotive industry portal: Who supplies whom and supplier database," 2026, accessed July 2026.

Appendix
Supplementary Configurations and Results

Model and retrieval settings. GPT-4.1 uses temperature 0 and a 2,048-token output limit. Qwen3 models are served with vLLM 0.25.1 in bfloat16 on one NVIDIA RTX 6000 Ada 48 GB GPU with a 16,384-token context and thinking disabled. Qwen3-14B uses a 1,024-token output limit, while Qwen3-8B and Qwen3-4B use 2,048 tokens. GPT-OSS-20B uses native MXFP4 weights, a 32,768-token context, an 8,192-token output limit, and low reasoning effort on the same GPU. Local runs use local embeddings and no hosted LLM fallback. Bootstrap resampling uses seed 42.

For the query-expansion experiment, reports are indexed as whole documents using OpenAI `text-embedding-3-small` embeddings with 1,536 dimensions over concatenated headline and body text. Retrieval uses cosine similarity and returns the top-ranked document for each query without a similarity threshold.

Note: Acceptance-filter recall is computed over retrieved relevant documents; all 39 retrieved target documents were retained.

Artifacts. Code, prompts, labeled reports, evaluation rubrics, saved outputs, analysis scripts, and the graph-interface specification are available for anonymous review at YOUR-ANONYMOUS-REPOSITORY-URL. The licensed MarkLines-derived graph cannot be redistributed.

TABLE 3. OURS ACROSS HOSTED AND LOCAL MODEL BACKENDS. FNR IS FN/99 AND FPR IS FP/30; PARENTHESES GIVE RAW COUNTS. LATENCY IS MEDIAN AND MEAN±SD; COST IS TOTAL EXTERNAL API EXPENDITURE FOR ALL 129 REPORTS. SUPPORT AND UNSUPPORTED-CLAIM RATES ARE FROM THE CLAIM–EVIDENCE AUDIT, WITH B2 IN PARENTHESES; ONLY THE GPT-5.4 ROW COMPARES FULL FINAL REPORTS, WHILE THE OTHERS USE STRUCTURED PERSISTED CLAIMS AND ARE DIAGNOSTIC.

Backend	**FNR ↓**	**FPR ↓**	**Supplier**	**Merge**	**Risk**	**Latency (s)**		**API cost**	**Support ↑**	**Unsup. ↓**
			μF1	**F1**	**QWK**	**Median**	**Mean±SD**	**($)**	**Ours (B2)**	**Ours (B2)**
GPT-4.1	4.0% (4)	0.0% (0)	0.850	0.750	0.620	7.7	6.9±2.9	1.19	0.979 (0.719)	0.021 (0.281)
GPT-5.4	4.0% (4)	0.0% (0)	0.851	0.709	0.640	15.5	14.2±5.7	2.60	0.958 (0.743)	0.042 (0.257)
GPT-OSS-20B	12.1% (12)	0.0% (0)	0.821	0.696	0.562	11.3	25.2±27.9	0	0.976 (0.687)	0.024 (0.313)
Qwen3-14B	8.1% (8)	0.0% (0)	0.811	0.715	0.443	27.6	24.9±9.2	0	0.978 (0.793)	0.022 (0.207)
Qwen3-8B	9.1% (9)	0.0% (0)	0.870	0.703	0.444	54.5	42.9±31.3	0	0.980 (0.691)	0.020 (0.309)
Qwen3-4B	11.1% (11)	0.0% (0)	0.829	0.701	0.407	9.7	9.7±6.2	0	0.979 (0.733)	0.021 (0.267)

TABLE 4. PAIRED INCIDENT-BLOCK BOOTSTRAP COMPARISONS (10,000 RESAMPLES, SEED 42). Δ IS OURS MINUS THE COMPARISON METHOD.

Comparison / Metric	Δ	**95% CI**
OURS–B2 Supplier μF1	+0.042	[-0.009, +0.105]
OURS–B2 Merge F1	+0.116	[-0.101, +0.305]
OURS–B2 Risk QWK	+0.031	[-0.073, +0.117]
OURS–B2 Spearman ρ	+0.112	[-0.036, +0.236]
OURS–A1 Risk QWK	+0.328	[+0.221, +0.436]
OURS–A3 Risk QWK	+0.266	[+0.160, +0.376]

TABLE 5. CONTROLLED QUERY-EXPANSION EVALUATION ON 20 INCIDENTS AND A 60-DOCUMENT RETRIEVAL CORPUS.

Metric	**Result**
Query top-1 success	97/100
Incidents with $\geq$1 relevant retrieval	20/20
Both supplemental reports retrieved	19/20
Relevant-document recall	39/40 (0.975)
Accepted-document precision	0.975
Acceptance-filter recall	1.000
Graph-attribute disclosure (manual audit)	0/100
Agent-5 evidence coverage	0.019 $\rightarrow$ 0.529
Risk-direction agreement	15/20 (0.750)

LLM Usage Statement

LLMs were used for editorial purposes in this manuscript, and all outputs were inspected by the authors to ensure accuracy and originality. LLMs were also integral to the experimental methodology for corpus generation and evaluated inference, as described in Sections 4.1, 4.3, and 4.4. The supply-chain graph is derived from licensed MarkLines data and is not redistributed. All generated reports describe synthetic events; no generated report asserts that the described incident occurred at the named supplier, and released artifacts will anonymize supplier identities. Local inference was performed on a single GPU to limit compute footprint.